

CREDENTIAL STUFFING

ATTACK — TIER 1 TRIAGE PLAYBOOK

Step-by-step investigation guide from the moment the alert fires to final disposition. Follow each step in order. Do not skip steps.

Alert ID	ALT-001
Severity	CRITICAL
Source	Auth Service / WAF
Host	auth-prod-01.internal
Source IP	185.220.101.47
Target User	admin@company.com
Action	BLOCKED
Time	02:14:33 EST
Dwell Time	4 minutes 33 seconds
Target TTR	Under 14 minutes

CRITICAL

PRIVILEGED ACCOUNT
TARGETED

TOR EXIT NODE

ACTION: BLOCKED

ANALYST BRIEF

This alert involves a CRITICAL severity attack against a privileged admin account from a confirmed Tor exit node. The WAF blocked it but your job is to VERIFY that block held for every single request — not assume it did.

1

Orient Before You Touch Anything

Top Nav + Metric Bar — 60 seconds

Before opening the alert, read the metric bar across the top of the dashboard. These five numbers tell you the state of the entire shift.

Metric	Value	What It Means
Critical Alerts	2	You are not the only fire. Two critical alerts need attention.
High Alerts	4	Six total alerts in queue — scan all before investigating any.
Mean TTR	14m	Your time benchmark. Stay under 14 minutes on this alert.
Closed Today	47	Shift is productive. Queue is being worked.
False Positive %	18%	Low FP rate — alerts are reliable. Treat this as real until proven otherwise.

ELEVATED THREAT LEVEL

Threat level is ELEVATED. Your false positive threshold is lower than normal. Something that looks borderline gets treated as real until proven otherwise.

Before opening ALT-001, scan the full alert queue. Check if any other alerts share the same IP (185.220.101.47), the same user (admin@company.com), or the same source system. Two related alerts should be worked as a connected incident.

2

Read the Alert Header First

Center Panel — Before clicking any tab

Open ALT-001. Before clicking Overview, Timeline, or anything else — read the four header chips. This is your case brief.

Chip	Value	Analyst Action
Alert ID	ALT-001	Your ticket reference. Every note, every query, reference this ID.
Hostname	auth-prod-01.internal	Authentication server — HIGH asset value. Not a workstation. Attacks here are more dangerous.
User	admin@company.com	Privileged account. If compromised, attacker has admin access. Treat this as high-priority target.
Action	BLOCKED	WAF stopped it. You are doing damage assessment, not active incident response. First relief.

CRITICAL QUESTION

The most important question the header raises: BLOCKED means the WAF stopped requests, but did the block fire BEFORE or AFTER any successful authentication? The 39-second enumeration window before the rule triggered is your investigation target.

3

Read the AI Triage Analysis

Overview Tab — Your starting hypothesis

AI TRIAGE ANALYSIS

A credential stuffing attack from Tor exit node 185.220.101.47 targeted admin@company.com with 12,400 requests per minute. All blocked by WAF. Attacker intent: privileged account takeover. Immediate action: verify block persistence and lock account.

What the AI analysis tells you:

- Tor exit node — deliberately anonymized malicious traffic. Not a misconfigured system.
- 12,400 requests per minute = 206 per second. Fully automated tooling. Not a human.
- Targeting admin@company.com specifically — the address appeared in a credential dump or user enumeration found it.
- Risk score 92/100 — red zone. Work it fast.

RISK SCORE 92/100

Risk Score 92/100 means this alert is in the top tier of urgency. The AI has factored in: confirmed malicious IP, privileged account, automated tooling, and known threat infrastructure. Do not deprioritize.

4

Investigate the IOCs

Right Panel + Threat Intel Tab

The right panel shows three Indicators of Compromise. Review each one before running lookups.

IOC Type	Value	Verdict	Score	What It Means
IP	185.220.101.47	MALICIOUS	98/100	Known Tor exit node. 847 abuse reports. Definitive — this is malicious infrastructure.
IP Subnet	91.108.4.0/22	SUSPICIOUS	67/100	Associated with known bad ranges. Note it — other IPs in this range may be part of the same campaign.
USER	admin@company.com	SUSPICIOUS	45/100	Flagged due to login volume. Account is not compromised — but needs immediate attention.

Click the Threat Intel tab → click Lookup on 185.220.101.47. The result will show:

- Verdict: MALICIOUS — Score 98/100 — Confidence 96%
- Detections: 847 out of 950 scanners flagged this IP
- Geo: Netherlands — ASN: AS4444 (Tor Project)
- Families: tor-exit-node, botnet-c2
- First seen: 2023-11-14 — actively reported

IOC VERDICT: CONFIRMED MALICIOUS

A score of 98/100 from threat intel combined with 847 abuse reports is as definitive as it gets. This is not a gray area. The source IP is confirmed malicious infrastructure.

5

Walk the Timeline

Timeline Tab — Establish kill chain and dwell time

Click the Timeline tab. Read from BOTTOM to TOP — oldest event first, newest last. This is how you read any log file.

Time (EST)	Dot Color	Event	Detail	Analyst Note
02:10:00	BLUE	First probe from IP	185.220.101.47 first contact	START of attack. Initial access timestamp.
02:13:50	AMBER	Anomalous login pattern	User enumeration phase detected	Attacker testing which usernames exist. 39-second window BEFORE WAF fired.
02:14:29	AMBER	WAF rate-limit fired	185.220.101.47 → /api/auth/login	Block rule triggered. 39 seconds AFTER enumeration started.
02:14:33	RED	Alert triggered	12,400 req/min — threshold exceeded	Detection timestamp. YOUR starting point.

Dwell time calculation:

Detection time: 02:14:33

Initial access time: 02:10:00

Dwell time: 4 minutes 33 seconds

THE 39-SECOND WINDOW

The 39-second window between 02:13:50 (enumeration started) and 02:14:29 (WAF fired) is where successful logins could have occurred. This is the exact window you are checking in Step 7 — Playbook Step 1.

6

Read the Raw Log

Raw Log Tab — Ground truth verification

Click the Raw Log tab. This is the actual log entry that triggered the alert. Read every field — the parsed overview is an interpretation, this is ground truth.

```
[2024-05-02T02:14:33Z] CRITICAL auth-prod-01 WAF[8821]: credential_stuffing

src_ip=185.220.101.47 dst_ip=10.0.1.15 port=443

user=admin@company.com req_count=12400 window=60s

rule_id=CS-001 action=BLOCK threat_intel=tor_exit_node

ua="python-requests/2.28.2"
```

Field	Value	What It Tells You
Timestamp	2024-05-02T02:14:33Z	ISO 8601 UTC. The Z means Zulu/UTC time. Convert to EST: 02:14:33.
Host	auth-prod-01	The machine that WROTE this log — the auth server being attacked.
src_ip	185.220.101.47	Single source IP. Not a distributed attack — one Tor exit node.
req_count=12400	window=60s	12,400 requests in 60 seconds. The WAF threshold rule fired on volume.
action	BLOCK	WAF rule CS-001 fired. BUT — check auth server logs separately to confirm no earlier successes.
ua	python-requests/2.28.2	Python HTTP library. No human uses this in a browser. Confirms automated tooling.

SMOKING GUN

python-requests/2.28.2 is the user-agent of an automated Python script. Zero legitimate users authenticate to a website using python-requests. This single field confirms the attack is fully automated and rules out any false positive scenario involving a human user.

7

Work the Response Playbook

Right Panel — Execute all 6 steps in order

Click through each playbook step in the right panel. Do not skip any. Check them off as you complete them. All 6 must be marked done before closing.

1

Verify no successful logins slipped through

CONFIRMATION GATE — Everything depends on this answer.

Run in your SIEM:

```
src_ip=185.220.101.47 AND user=admin@company.com AND action=success
```

Also check the 39-second enumeration window:

```
timestamp BETWEEN 02:13:50 AND 02:14:29 AND action=success
```

— ZERO RESULTS → continue. ANY RESULTS → stop. Escalate to Tier 2 immediately.

2

Confirm the block is still active

Some WAF rate-limit rules expire after 5-10 minutes.

— Verify 185.220.101.47 is still blocked — not just that it was blocked at 02:14:33

Check if the attacker has rotated to a new IP in subnet 91.108.4.0/22

— Consider blocking the full /22 subnet at the perimeter

3

Lock admin@company.com

Disable — not password reset — in Active Directory or identity provider.

— Contact account owner through a verified channel (not email)

— DISABLE the account — a password reset doesn't prevent hash replay

— Account stays disabled until owner confirms via secondary channel

4

Check for sibling attacks

Credential stuffing bots spray entire lists — not just one account.

Run: `src_ip=185.220.101.47 | stats count by user`

— This shows every account the bot targeted in the same session

— For each account with login attempts: run the Step 1 query against them too

5

Notify the identity team

Five facts: alert ID, source IP, targeted account, volume, action taken.

— Do not write a novel — five facts only

```
ALT-001 | 185.220.101.47 | admin@company.com | 12,400 req/min | BLOCKED
```

— They need to know for access review even if the attack failed

6

Search for credential dumps

Why was THIS account targeted? Check if it appeared in a known dump.

[Check Have I Been Pwned for admin@company.com](#)

[Check your dark web monitoring feed if available](#)

- If found in a dump → credentials are known → attacker will try again from a different IP
- If found → escalate to identity team for mandatory credential rotation

8

Pressure-Test with AI Chat

Bottom Chat Bar — Quality check before closing

Before you close this alert, use the AI chat to pressure-test your findings. Type these questions in the chat bar at the bottom of the dashboard.

Question to ask	What the answer tells you
"Is this a true positive or false positive and why?"	AI will weigh all evidence. If it says FP, it will give you a specific reason. If TP, it will confirm your analysis.
"What would a false positive version of this activity look like?"	Forces you to consider the benign explanation. A legitimate load test? A developer script? If none apply, you have your confirmation.
"What other log sources should I check to corroborate this alert?"	Surfaces log sources you might have missed — DNS logs, proxy logs, auth server logs separate from WAF.
"What evidence would change my disposition from close to escalate?"	This is your escalation gate. If any of those conditions exist in your investigation, you should not close.
"What should I document before closing this alert?"	Run this last. Gives you a complete documentation checklist for your case note.

9

Write Your Case Note

AI Chat — Documentation before disposition

Before hitting Close, write your case note in the AI chat. This is your audit trail. Copy this template and fill in your findings:

```
ALT-001 – Credential stuffing from Tor exit node 185.220.101.47

targeting admin@company.com. 12,400 req/min – all blocked by WAF

rule CS-001. Zero successful authentications confirmed via SIEM query.

IP blocked at perimeter. Subnet 91.108.4.0/22 noted for monitoring.

Account admin@company.com disabled pending owner notification.

No sibling accounts with successful logins detected.

No credential dump matches found.

Dwell time: 4m33s pre-detection.

Closed as contained – no escalation required.
```

Five things every case note must include:

- What happened — the attack type, source, target, volume
- What you confirmed — specific queries run and their results
- What you did — containment actions taken with timestamps
- Current state — is the threat neutralized? Account status?
- Open items — anything that needs follow-up

1
0**Disposition: Close the Alert**

Alert Header — Dismiss / Escalate / Close

Hit the Close button. The inline modal will ask you to confirm. Before you click confirm, run this final mental checklist:

✓	All 6 playbook steps marked complete	Required
✓	Zero successful logins confirmed via SIEM query	Required
✓	Block verified as still active at perimeter	Required
✓	admin@company.com disabled and owner notified	Required
✓	Sibling accounts checked — no other compromises	Required
✓	Credential dump check complete	Required
✓	Case note written with all five required elements	Required

DISPOSITION DECISION RULE

If ALL seven items are checked: hit CLOSE. If ANY item came back with a hit — especially Step 1 (successful login found) — hit ESCALATE and fill out the Tier 2 handoff note immediately.

Escalation triggers — any one of these means ESCALATE, not CLOSE:

- Any successful authentication found in the 39-second enumeration window
- Attacker authenticated to any other system using the same credentials
- admin@company.com shows signs of active session before you disabled it
- Credential dump confirms password is known to threat actors
- More than 3 other accounts show successful logins from the same IP range

Step	Action	Zone	Time Target	Decision Gate
1	Orient — read metric bar	Top Nav	60 sec	Check threat level + scan all alerts before opening any
2	Read alert header chips	Center Header	30 sec	BLOCKED = damage assessment. DETECTED = active response.
3	Read AI triage analysis	Overview Tab	60 sec	Risk 92/100 = critical priority. Work immediately.
4	Investigate IOCs	Right Panel + Intel	90 sec	Score 98/100 confirmed malicious. No gray area.
5	Walk timeline	Timeline Tab	60 sec	Find 39-sec enumeration window. Calculate 4m33s dwell time.
6	Read raw log	Raw Log Tab	30 sec	python-requests confirms automation. Eliminates FP.
7	Work playbook — all 6	Right Panel	8 min	Step 1 is gate. Zero successful logins = proceed. Any = escalate.
8	AI chat pressure test	Chat Bar	90 sec	5 questions before close. Surface anything missed.
9	Write case note	Chat Tab	2 min	5 required elements. Your audit trail.
10	Close or Escalate	Header Buttons	30 sec	7-point checklist. All green = Close. Any red = Escalate.

"Telemetry always tells the truth. You just have to slow down long enough to understand what the environment is saying."

— Jarius Glover · github.com/KickingCyb3r · medium.com/@kickingcyb3r